Messagerie souveraine de l'administration

Équipe : **[NOM DE L'ÉQUIPE]** · [UNIVERSITÉ] · Dépôt : github.com/AkimM226/messagerie-souveraine

1. Menaces prises en compte et protections

Menace	Protection mise en place
Lecture des messages par le serveur, son administrateur ou un attaquant qui vole la base	**Chiffrement de bout en bout** Olm/Megolm (Matrix) des messages et des fichiers, fait par le client. Le serveur ne stocke que des blocs `m.room.encrypted` ; vérifié : une recherche du texte dans une copie complète de la base donne 0 résultat.
Interception du trafic réseau	Contenu déjà chiffré de bout en bout ; transport en HTTPS via Caddy (certificats de l'État ou autorité interne).
Personne non autorisée qui tente de s'inscrire ou d'entrer dans un groupe	Inscription désactivée, aucun mot de passe local dans Synapse : connexion uniquement via Keycloak (OpenID Connect + PKCE). Synapse exige le rôle `agent` ; un compte sans ce rôle est rejeté. Aucun invité, aucune fédération.
Vol ou devinette du mot de passe	**Second facteur TOTP obligatoire** pour tous (parcours de connexion « mot de passe + code », non conditionnel) ; protection contre la force brute (blocage temporaire après 5 échecs).
Agent qui quitte son poste, téléphone perdu ou volé	**Révocation immédiate** en une commande : compte Keycloak désactivé et sessions fermées ; compte Matrix désactivé (jetons, appareils et clés supprimés, retrait de tous les groupes). Les autres membres changent de clé de groupe : l'agent ne peut plus lire aucun nouveau message. Testé : effectif en 2 s, reconnexion refusée.
Dépendance ou fuite vers un service étranger	Aucun service tiers : pas de serveur de clés matrix.org, pas d'intégrations, de visio externe, d'aperçus de liens, de statistiques ni de rapports d'erreurs. Tout tourne sur l'infrastructure de l'État.
Conservation excessive d'échanges sensibles	Salons **classifiés à expiration automatique** ; un salon classifié ne peut être ni déclassé, ni rendu public, ni classifié après coup (aucune destruction rétroactive d'historique).
Accès aux outils d'administration	API d'administration Synapse et console Keycloak **non exposées** (403 depuis l'extérieur) ; accessibles seulement depuis le serveur. Le compte `admin.securite` est lui-même soumis au 2FA.

2. Ce que le serveur voit malgré tout (métadonnées)

Le serveur ne lit **aucun contenu**. Pour acheminer les messages, il voit cependant :

- **qui échange avec qui** : la liste des membres de chaque salon et l'expéditeur de chaque message ;
- **quand** : l'horodatage de chaque message, et sa taille approximative ;
- **les noms et sujets des salons** (non chiffrés dans Matrix) — d'où la consigne de n'y mettre aucune information sensible ;
- la liste des appareils de chaque agent et leurs clés publiques ; les adresses IP de connexion ;
- les accusés de lecture et indications de saisie, si l'agent les laisse activés.

Mesures prises pour réduire ces métadonnées : statut de présence (« en ligne ») désactivé ; adresses IP conservées 1 jour au lieu de 28 ; profils visibles uniquement entre agents partageant un salon ; aucune fédération (les métadonnées ne quittent jamais le serveur de l'État) ; contenu d'un message supprimé effacé du serveur après 1 heure ; expiration automatique dans les salons classifiés, qui efface aussi les traces des échanges ; aucun annuaire public de salons.

3. Limites connues

- **Démonstration en HTTP local** (`*.localhost`) : en production, HTTPS est obligatoire (Caddy l'active avec un vrai domaine).
- **Secrets de démonstration dans le dépôt** (mots de passe des comptes fictifs, base de données, administrateur Keycloak) : à remplacer dans `.env` avant tout déploiement réel.

- **Administrateur malveillant** : il ne peut pas lire les messages passés, mais pourrait ajouter un faux appareil à un compte. Parade : vérification croisée des appareils (cross-signing) proposée par Element, qui signale tout appareil non vérifié.
- **TOTP n'empêche pas l'hameçonnage** en temps réel ; évolution prévue vers les clés physiques (WebAuthn/FIDO2), déjà supportées par Keycloak.
- **Après révocation**, les messages déjà déchiffrés et affichés sur l'appareil ont pu être lus ou copiés ; l'effacement à distance des données locales n'est pas encore implémenté.
- **Classification** : le serveur ne peut empêcher ni une capture d'écran ni le copier-coller d'un message (il ne voit pas le contenu) ; les messages expirés sont supprimés au nom de leur auteur (mention « Expiration automatique ») ; un message peut rester quelques instants sur un appareil hors ligne jusqu'à sa synchronisation.
- Un seul serveur, sans haute disponibilité ni sauvegarde automatisée dans ce prototype.